GhostNote ? Forensics Writeup

Prompt

A senior employee discovered that confidential meeting notes were appearing
outside the organization. No suspicious authentication activity was identified
in the employee's cloud accounts. A forensic triage package was collected
from the workstation.

Determine what happened and recover the flag.
Flag format: `Tvx{40_lowercase_hex_characters}`

Flag

```
Tvx{7312f376b0786df4db8a8950057228fb246e5013}
```

Summary ? what happened

This was not a cloud-account compromise. A fake Notion updater,
`NotionUpdate.exe`, was dropped in the user's own AppData, executed by the
real `Notion.exe`, read the local Notion `vault.db` (including the
Confidential "Q3 Board Meeting" note), derived a session key from the
vault's device secret and its real command-and-control (C2) host, and made
an outbound connection to that host on port 8443 ? exfiltrating the notes
locally, with no cloud login involved.

Step by step

1. Triage inventory

`GhostNote.zip` contains only seven files: `Evidence/Sysmon.xml`,
`Timeline/ExecutionArtifacts.csv`, a registry export (`NTUSER.DAT.reg`),
`vault.db`, `NotionUpdate.exe`, and two Desktop decoys
(`vpn_backup.conf`, `company-root-ca.pem`).

Sysmon EventID 1: `NotionUpdate.exe --silent-sync`, parent
`C:\Program Files\Notion\Notion.exe`, SHA256
`3d84616670cdbe3eabc870b5e732bf4ede26966179ba39f874e67cf1ea2acbda` ?
this exactly matches the supplied binary (6,656 bytes), so it is the
right sample despite the Amcache line claiming "94 KB".

Sysmon EventID 3 at 21:42:18Z: the same binary connects out, TCP,
port 8443. Prefetch/Amcache agree on first execution at 21:39:44Z.

2. The vault

`vault.db` is SQLite with three tables:

- `notes` ? Q3 Board Meeting (Confidential), Budget Review and Travel
  (both Internal). The Q3 note is the leaked material.
- `identity` ? `deviceSecret = eiHYlLXXBMofKkmAhk5S3n+VjdOfjNMjIvfFaA/Y9L0=`,
  Base64 for the 32 raw bytes
  `7a21d894b5d704ca1f2a4980864e52de7f958dd39f8cd32322f7c5680fd8f4bd`.
- `config` ? `serverValidation = 2be46ca73aacd65f76539df5d2157357d44bf060736cc92e457642daad0be83c`.

3. Reversing NotionUpdate.exe

PE32+ x86-64, no imports, entry point is a trap loop. The useful
information is in its export table (12 exports). Resolved via the export

address / name / ordinal tables:

Export	RVA	Meaning
GhostNote_decodeServer	0x1000	XOR-decode a C2 blob
GhostNote_deriveSession	0x1110	SHA256(32-byte secret ? string)
GhostNote_extractHostLower	0x1050	host after `://`, to `:` or `/`, lower-cased
GhostNote_finalFlagDigest	0x1480	SHA256(32-byte secret ? string ? string)
GhostNote_getC2	0x1650	return blob 0, 1 or 2 by index
GhostNote_validationDigest	0x1350	SHA256(32-byte input ? "GHOSTNOTE")
GhostNote_identityQuery / validationQuery / vaultPath	0x3008 / 0x3010 / 0x3000 (.data)	the SQL queries and vault path
GhostNote_profilePath / profileValue	0x3018 / 0x3020 (.data)	`HKCU\...\Explorer\SessionInfo` / `SyncProfile`
GhostNote_validationTag	0x3028 (.data)	the string `GHOSTNOTE`

`getC2` indexes a small offset table at RVA 0x21b0 pointing at three blobs at RVA 0x2000, 0x2030, 0x2060. `decodeServer` XORs each byte with `0x37` and stops at a raw `0x37` byte, which decodes to NUL:

```
0: wss://notion-assets-cdn.com:9443/update
1: wss://SYNC-NOTES-SERVICE.CLOUD:8443/api/v2
2: wss://notes-edge-cache.net:443/sync
```

4. Identifying the real C2 ? the validation oracle

For each candidate, extract the lower-cased host, then:

```
session    = SHA256(secret || host)
validation = SHA256(session || "GHOSTNOTE")
```

Host	Validation
notion-assets-cdn.com	27a52acc9d35a28b9df34a6702d411acf6111cfbabb32f6aa938c86bb170b8bc
sync-notes-service.cloud	**2be46ca73aacd65f76539df5d2157357d44bf060736cc92e457642daad0be83c ? exact match**
notes-edge-cache.net	b455b29fac9ead46bd6379f8260f50615b5c77505b10573fca1511575ef19db1

Only candidate 1, `sync-notes-service.cloud`, reproduces `serverValidation`. It is independently corroborated: its URL port is 8443, exactly the DestinationPort in the Sysmon network event. Its session key is `491c23308367437f6ce63cfcdfa3eca2934d3c0431a1b7957d1ed97f5fb46866`.

Decoys rejected on the same evidence: the VPN file is self-labelled "do not use in production", its token decodes to `some_fake_token`, and its 32-byte `PublicKey` produces no validation match; the Desktop certificate body literally reads `CHALLENGE_DECOY_CERT` / `decoy-certificate-for-ctf-only-not-real`.

5. The campaign name

The certificate's Base64 comment decodes to:

```
THE IDENTITY OPENS THE DOOR, BUT THE PROFILE NAMES THE CAMPAIGN.
```

The identity is the `deviceSecret` used above. The profile is in the UTF-16 registry export, at exactly the key/value the binary exports point to (`SessionInfo` / `SyncProfile`):

```
"SyncProfile"="GNT-0926"
```

6. Final flag digest

`GhostNote_finalFlagDigest(secret, host, campaign)`, i.e. the same argument shape as `deriveSession(secret, host)`, with the campaign appended:

```
SHA256(secret || "sync-notes-service.cloud" || "GNT-0926")
 = 7312f376b0786df4db8a8950057228fb246e5013f4723a06376245ba22e31c71

flag = "Tvx{" + digest[:40] + "}"
     = Tvx{7312f376b0786df4db8a8950057228fb246e5013}
```

Solver

```
unzip ghostnote_writeup.zip && cd ghostnote_writeup
python3 solvers/solve_all.py
```

Stdlib only. It re-reads `vault.db` and the binary from the original `GhostNote.zip` in `challenges/`, re-validates all three C2 candidates against `serverValidation` (printing the match), and prints the flag. Fresh-unzip test: 1/1.

Lesson

"No suspicious cloud logins" does not mean no exfiltration: a sideloaded updater in AppData with access to a local app vault can read and send the data itself. The giveaways were all local ? an unsigned updater in a user-writable path, a Sysmon outbound connection, and a validation value in the vault that uniquely identified the real C2 host among decoys.